KILL CHAIN BREACH ANALYSIS

Analyst: Varun Chowdary Challagundla

Date: 27 October 2026

Subject: Customer data breach at a mid-sized company (phishing email through to database theft)

Source: A composite based on common real-world breach patterns

1. BREACH SUMMARY

A mid-sized company was breached by an attacker whose goal was to steal the customer database. The attacker researched the company, phished finance staff with a fake supplier invoice, exploited outdated software to gain a foothold, and then spent weeks moving through the network to reach the database server. The attack succeeded: the entire customer database was copied out, and the breach was only discovered when the stolen data appeared for sale.

2. KILL CHAIN MAPPING

- **RECONNAISSANCE:** The attacker studied the company website, found employees on professional networks, worked out the email address format, and identified the names of finance department staff.
- **WEAPONIZATION:** The attacker built a malicious attachment disguised as an invoice, containing code that exploits a vulnerability in outdated software.
- **DELIVERY:** The attacker sent a phishing email impersonating a known supplier to several finance employees, with the fake invoice attached.
- **EXPLOITATION:** One employee opened the attachment. It exploited a vulnerability in outdated software on their computer, which ran the attacker's code and gave the attacker an initial foothold on that machine.
- **INSTALLATION:** The attacker installed a backdoor and created a hidden scheduled task so that access would survive a restart of the computer.
- **COMMAND AND CONTROL:** The compromised machine quietly connected out to a server controlled by the attacker. This let the attacker send commands and operate inside the network remotely.
- **ACTIONS ON OBJECTIVES:** Over several weeks the attacker explored the network from the foothold, stole credentials, and moved to other systems until reaching the server holding the customer database. They then copied the entire database out of the network to their own server. The goal was achieved. The breach was discovered later, when the data appeared for sale.

3. TECHNIQUES USED (ATT&CK THINKING)

Stage	Technique	Tactic
Reconnaissance	Gathering victim identity and employee information from public sources (website, professional networks)	Reconnaissance

Stage	Technique	Tactic
Delivery	Phishing email with a malicious attachment, impersonating a trusted supplier	Initial Access
Exploitation	Exploiting a vulnerability in unpatched software	Execution
Installation	Backdoor plus a hidden scheduled task	Persistence
Command and Control	Outbound beaconing to an attacker-controlled server	Command and Control
Actions on Objectives	Credential theft; moving to other systems; copying the database out to the attacker's server	Credential Access; Lateral Movement; Exfiltration

4. WHERE THE CHAIN COULD HAVE BROKEN

- **Reconnaissance:** Limit public exposure of staff details and raise staff awareness about oversharing. This makes the phishing less targeted and convincing, but it is a weak break point because public information is hard to hide.
- **Delivery:** Email filtering (attachment scanning, supplier impersonation checks) plus phishing-awareness training. The email never arrives, or the employee recognises it as fake and does not open it.
- **Exploitation:** Patching the outdated software. The attachment may open, but the exploit has nothing to exploit, so no code runs and no foothold is gained.
- **Installation:** Monitoring for new or unusual scheduled tasks and unknown programs. The backdoor and persistence are detected and removed before the attacker settles in.
- **Command and Control:** Beaconing detection and outbound traffic filtering. The compromised machine cannot reach the attacker's server, so the attacker loses remote control.
- **Actions on Objectives:** Alerts on unusual database access and large outbound data transfers (data loss prevention), plus network segmentation and tight access controls. The credential theft, lateral movement, or exfiltration is caught or blocked.

MOST EFFECTIVE DEFENCE: patching the outdated software (Exploitation stage)

It removes the root cause. Without the vulnerability, the malicious attachment fails even if the phishing email is delivered and opened, which matters because phishing defences can never be perfect and someone will eventually click. It also stops the attack at the earliest technical point, before the attacker has any foothold, so nothing needs to be detected or cleaned up later.

5. LESSONS THAT GENERALISE

1. **Patch promptly:** Known, unpatched vulnerabilities are among the most common ways into an organisation. In this breach, one unpatched flaw made the whole attack possible.
2. **Do not rely on a single layer:** Email filtering and training reduce phishing risk but never eliminate it, so later layers must be ready to catch what slips through.
3. **Watch for what happens after the break-in:** Persistence (such as hidden scheduled tasks) and outbound connections (beaconing) are detectable, but only if someone is monitoring them.

4. **Limit how far an intruder can go:** The attacker moved through the network for weeks and reached the database server. Segmentation and tight access controls make lateral movement harder.

6. KEY TAKEAWAY

The attacker had to succeed at every one of seven stages, while the defender only had to win once. This organisation missed at least five chances (patching, email filtering, persistence monitoring, outbound traffic monitoring, and data-transfer alerts) and learned of the breach from the black market instead of from its own systems.